DATA PRIVACY AND SECURITY NOTE

How Udyam Digital protects owner and signatory data

The data pack is synthetic, but we treat it as real personal data under the **DPDP Act, 2023**. The design applies consent, purpose limitation, data minimisation, storage limitation, security and erasure.

What we collect	How it is handled	Kept for
Business profile	Business name and type, city, headcount, connectivity, budget, optional GSTIN, contact name and mobile. No documents or ID numbers are asked at this step. GSTIN is masked in every response.	With the order
KYC documents	Exactly four: GST certificate, Udyam certificate, signatory ID, utility bill. Asked only after consent. OCR runs on our own server, files are encrypted at rest, and nothing is shared or used for marketing.	Deleted automatically after 30 days
ID numbers and extracted fields	GSTIN, Udyam, ID and consumer numbers are encrypted in the database and masked in every API response, screen and log (**27**********1ZP**). They never go to the AI provider.	30 days; the outcome is kept as the audit record
Advisor chat and voice	The chat stores what the customer types. With an AI key set, the typed message, a short history and catalogue facts go to the AI provider. Voice is optional: the browser's speech service, or a clip of at most 25 s sent after an explicit prompt and never stored by us.	Chat stored with the journey; voice clips never stored
Payments	The amount is computed on the server. Card numbers and CVVs are never stored or logged (a hosted gateway window takes them in production). Webhooks are HMAC-verified.	Card network and last four digits only

Consent and purpose

- A dedicated consent screen comes before any upload. It lists three purposes: verify identity and registrations against registries, match address proof, and create and activate the account.
- It also states the retention period and the right to delete.
- Consent is recorded with timestamp, notice version, purposes and retention days. Uploads are refused without it.
- A customer can decline and verify through the field team instead.

Human oversight and fairness

- Every rejection or mismatch states the reason and the fix.
- Borderline cases (**needs_review**) go to a person. The system never auto-rejects on a fuzzy match.
- Eligibility and prices are rule-based and reproducible, so decisions can be explained and audited. The AI cannot change them.

Security

- Files are encrypted at rest (Fernet/AES with HMAC) under random names, outside the web root. Extracted fields and declared identifiers are encrypted in the database.
- bcrypt password hashes, JWT sessions, role checks, and owner-scoped queries (other users' orders return 404).
- Upload checks (magic bytes, 8 MB, PNG/JPG), rate limits, parameterised queries and generic error bodies.
- Secrets live in environment variables. The AI key stays on the server, and the browser only talks to a same-origin proxy.
- Documents never leave the server: OCR runs locally and registry checks use the supplied mock files.

Retention and erasure

- Documents and extracted data are deleted after 30 days (purge at startup and as an admin job). The purge date shows next to every upload.
- The customer can delete all documents and withdraw consent at any time. This removes files, extracted data and declared identifiers.
- Only the KYC outcome (status and issue codes) stays with the order as the audit record.

Known gaps in this prototype

Rate limiting is in memory on a single process. The encryption key derives from the JWT secret unless **ENCRYPTION_KEY** is set; in production set it, ideally from a KMS. There is no DigiLocker consent artefact or e-sign yet. There is no formal DPIA, breach-notification workflow or data-processor agreement with the AI provider: a free-tier key may let the provider use chat text and voice clips to improve its products, so use a paid tier with an agreement in production. Backups and replicas are not covered by the purge job.